

## PILLAR B · FREE GOVERNANCE GUIDE

# Safe AI Use Guide

Six chapters. Written for community banks and credit unions. Aligned with SR 11-7, Interagency TPRM Guidance, ECOA/Reg B, and the AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC — February 2026).

*Turning Bankers into Builders.*

## CONTENTS

- 01 The never-paste list
- 02 Private cloud vs. public model
- 03 Mapping to SR 11-7
- 04 Vendor evaluation scoring
- 05 Shadow AI discovery
- 06 Examiner readiness

# The never-paste list.

Six categories of data that must never touch a public large language model — and the regulatory reasoning behind each prohibition.

**Standing rule — no exceptions**

A public LLM is a third party. Any data entered into a public LLM prompt is transmitted outside your institution's security perimeter. When in doubt about a data category not listed here, apply the same analysis: would you email this to an unknown vendor? If no, do not paste it.

| DATA CATEGORY               | COMMON EXAMPLES                                                                      | REGULATORY / LEGAL BASIS                                                                                                                                                   |
|-----------------------------|--------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Member / Customer PII       | Names, SSNs, account numbers, DOBs, addresses, phone numbers, email addresses        | GLBA Safeguards Rule requires data minimization and limits disclosure. Submitting PII to a public LLM constitutes an uncontrolled third-party disclosure.                  |
| Loan application data       | Income figures, employment history, credit scores, debt schedules, collateral values | ECOA / Reg B, FCRA, and Fair Lending obligations attach to this data. Adverse action analysis performed by an unvalidated model triggers SR 11-7 model risk requirements.  |
| Non-public examination data | CAMELS ratings, MRAs / MRIs, examination reports, supervisory communications         | Federal law prohibits unauthorized disclosure of examination information (12 U.S.C. § 1828(x)). Regulators have cited institutions for inadequate controls over this data. |
| BSA / AML records           | SAR narratives, CTR details, OFAC screening results, beneficial ownership records    | SAR confidentiality provisions (31 U.S.C. § 5318(g)) carry criminal penalties for unauthorized disclosure. Training data contamination is an unresolved legal risk.        |
| Internal audit & legal      | Draft audit findings, attorney-client communications, litigation hold materials      | Privilege can be waived by disclosure to third parties. Public LLM terms of service typically do not preserve attorney-client or work-product protections.                 |
| Vendor contracts & pricing  | Core processor MSAs, fintech contracts, negotiated rate schedules                    | Most contracts contain confidentiality clauses. Disclosure to a public LLM may constitute a breach triggering liability.                                                   |

**Practical staff test**

Before pasting: ask "Does this contain a real person's information, a real account's data, or information I received under a regulatory expectation of confidentiality?" If yes to any: stop. Use only synthetic or fully anonymized data for AI-assisted drafting and analysis.

Regulatory basis: GLBA Safeguards Rule (16 C.F.R. Part 314), ECOA / Reg B (12 C.F.R. Part 202), BSA SAR confidentiality (31 U.S.C. § 5318(g)), 12 U.S.C. § 1828(x).

# Private cloud vs. public model.

A structured decision tree every staff member should run before entering data into any AI tool. Five questions.  
One clear answer.

Not every AI use case requires private infrastructure. The following decision tree determines the minimum deployment tier for a given task based on data sensitivity, regulatory exposure, and output use. Walk each question in order — stop at the first YES that directs you to a deployment tier.

Q1 Does the task require inputting any data from the never-paste list (Chapter 1)?

YES → Private inference required. Approved private cloud or on-premises deployment only. Public models prohibited.

NO → Continue to Q2.

¼

Q2 Will the AI output be used to make or support a credit, compliance, or hiring decision?

YES → Private inference required. Output constitutes a model output under SR 11-7 and requires validation, documentation, and an independent review.

NO → Continue to Q3.

¼

Q3 Does the vendor's terms of service permit training on submitted data?

YES → Public model not permitted for internal use cases. Evaluate enterprise tier (training opt-out) or private deployment.

NO (training opt-out confirmed in writing) → Continue to Q4.

¼

Q4 Is the data classified as Internal Only (not public-facing, not restricted)?

YES → Enterprise-licensed tier required (e.g., Microsoft 365 Copilot, Google Workspace Gemini with DLP controls). Consumer / free-tier tools prohibited.

NO (data is genuinely public-domain or synthetic) → Continue to Q5.

¼

Q5 Is the institution's AI vendor inventory list approved and does this tool appear on it?

YES (approved tool, public data only) → Public model permitted. Document use case in AI use case inventory per AIEOG guidance.

NO → Do not use. Submit for vendor evaluation (see Chapter 4) before proceeding.

Framework basis: SS&C Managed IT Hybrid Multi-Cloud AI Strategy (2025) — "PII never in public LLMs; private cloud for sensitive inference; Zero Trust + RBAC." SR 11-7 Model Risk Management (FRB, 2011). AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC, February 2026.

# Mapping to SR 11-7.

Model Risk Management guidance was written for statistical models. It applies to generative AI — here is the mapping with action language for your governance framework.

What examiners are asking

Per GAO-25-107197 (May 2025): there is no comprehensive AI-specific banking framework yet. Examiners are applying existing guidance — SR 11-7 for model risk, Interagency TPRM for vendor oversight — through the lens of the AIEOG AI Lexicon. Institutions with documented governance frameworks are significantly better positioned in examinations.

| SR 11-7 COMPONENT                          | GENERATIVE AI EQUIVALENT                      | ACTION FOR YOUR FRAMEWORK                                                                                                                                           |
|--------------------------------------------|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Model development, implementation, and use | Generative AI system selection and deployment | Document intended use case, data inputs, and business process before deployment. Assign a model owner.                                                              |
| Model validation                           | Output accuracy and hallucination testing     | Establish a challenge / validation process. For high-stakes outputs (credit, compliance), require human review of AI-generated content before use.                  |
| Ongoing monitoring                         | Model drift and output quality degradation    | Track output quality over time. Establish a trigger for re-evaluation when foundational model is updated by vendor.                                                 |
| Model inventory                            | AI use case inventory                         | Maintain a living register of every AI tool in use, its data inputs, business purpose, and risk tier. AIEOG AI Lexicon defines this as the "AI use case inventory." |
| Third-party model risk                     | Vendor / API-based AI services                | Apply Interagency TPRM Guidance to all AI vendors. Obtain SOC 2 Type II, review data retention terms, confirm right-to-audit clause.                                |
| Sensitivity analysis and stress testing    | Adversarial prompt / red-team testing         | For any AI model used in lending or compliance decisions: conduct red-team testing for prompt injection, jailbreaks, and data leakage before production.            |
| Independent review function                | AI governance committee                       | Establish a cross-functional AI governance committee (IT, Compliance, Risk, Operations, Audit) with quarterly review cadence and board reporting.                   |

Sources: SR 11-7 Supervisory Guidance on Model Risk Management, Federal Reserve Board (2011). GAO-25-107197, US Government Accountability Office (May 2025). AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026).

# Vendor evaluation scoring.

Five questions. Score 0–3 on each for a maximum of 15. Minimum passing score: 9. Below 9: do not deploy without remediation plan and board notification.

## 15

Approved

## 12–14

Approved with conditions

## 9–11

Conditional — remediation required

## < 9

Do not deploy

### Q1 Data handling and retention

Does the vendor contractually commit to zero training on your submitted data? Is retention period documented and within your TPRM policy limits?

#### 3

Written opt-out confirmed; data deleted within 30 days

#### 2

Training opt-out available; retention policy unclear

#### 1

No opt-out; data retained for model improvement

#### 0

Terms silent on training or retention

### Q2 Security certifications

Does the vendor maintain SOC 2 Type II, ISO 27001, or FedRAMP certification? Current within 12 months?

#### 3

SOC 2 Type II current; penetration test available

#### 2

SOC 2 Type I or ISO 27001 only

#### 1

Certification in progress; not yet issued

#### 0

No third-party security certification

### Q3 Right to audit and subprocessors

Does the contract include a right-to-audit clause? Are all material subprocessors disclosed and subject to equivalent controls?

#### 3

Right-to-audit confirmed; subprocessors listed and auditable

#### 2

Audit rights limited to questionnaire; subprocessors disclosed

#### 1

No right to audit; subprocessors partially disclosed

#### 0

Contract silent; subprocessors not disclosed

### Q4 Concentration risk

What share of your AI-dependent workflows would this vendor represent? Does adding this vendor create excessive concentration in a single provider?

#### 3

Under 25% of AI workflows; redundancy plan exists

#### 2

25–50% of AI workflows; backup vendor identified

#### 1

Over 50% of AI workflows; no fallback plan

#### 0

Single point of failure; no contingency

### Q5 Explainability and human-in-the-loop

For outputs used in decisions: does the system provide an explanation of its reasoning? Is human review required before action is taken?

#### 3

#### 2

#### 1

#### 0

|                                                          |                                                  |                                           |                                        |
|----------------------------------------------------------|--------------------------------------------------|-------------------------------------------|----------------------------------------|
| Explanations available; HITL required by workflow design | Explanations available on request; HITL optional | Limited explainability; HITL not enforced | Black-box output; no human review step |
|----------------------------------------------------------|--------------------------------------------------|-------------------------------------------|----------------------------------------|

Framework basis: Interagency Guidance on Third-Party Relationships: Risk Management (OCC, FRB, FDIC, 2023). AIEOG AI Lexicon definitions: "human-in-the-loop (HITL)," "explainability," "third-party AI risk" (February 2026).

# Shadow AI discovery.

A structured five-phase method for identifying the AI tools your staff are already using — and bringing them inside a governance perimeter without killing adoption.

## Why this matters now

Gartner research (via Jack Henry, 2025) finds 57% of financial institutions report AI skill gaps and 55% have no AI governance framework yet. The most common root cause: staff adopted tools independently before governance existed. A punitive discovery process drives shadow AI further underground. This method is designed to surface tools through trust, not surveillance.

### Phase 1

## Anonymous discovery survey

Week 1

Deploy a short anonymous survey to all staff: "What AI tools do you use in your work, including personal tools?" Guarantee no individual responses will be reviewed by management. Psychological safety is the key variable — without it, staff underreport by an estimated 60–80%.

### Output

Raw inventory of AI tools in use, segmented by department.

### Phase 2

## DNS / proxy log review

Week 1–2

Pull 30-day outbound DNS queries or proxy logs. Search for known AI domains: openai.com, claude.ai, gemini.google.com, perplexity.ai, character.ai, and emerging tools. Cross-reference against approved vendor list.

### Output

Gap list: tools in use but not on approved inventory.

### Phase 3

## Department interviews

Week 2–3

Conduct 20-minute structured interviews with department heads. Ask: "Walk me through a week of work — where do you use AI?" Do not begin with compliance questions; begin with productivity. Note: Lending, Operations, and IT typically surface the highest shadow AI counts.

### Output

Use-case map per department; identification of high-risk workflows.

Classify each discovered tool against the decision tree from Chapter 2. Tools receiving scores that indicate private inference requirements but running on public models are Tier 1 remediation priorities.

**Output**

Risk-tiered shadow AI register.

Bring each tool through the vendor evaluation framework (Chapter 4). Tools scoring 9+ and aligned to approved data tiers: add to official AI use case inventory. Tools scoring below 9: notify users, provide approved alternatives, document decision.

**Output**

Updated AI use case inventory; closure notification to affected staff.

Data: "Getting Started in AI," Jack Henry & Associates (2025) – 57% skill gaps, 55% no governance framework, sourced from Gartner Peer Community research. Shadow AI underreporting estimate: Gartner (2024).



# Examiner readiness.

What to have on the table when an examiner walks in. Built around the official AIEOG AI Lexicon vocabulary — the first cross-agency AI governance vocabulary for financial institutions.

## The examiner context

The AIEOG AI Lexicon (US Treasury, FBIIC, FSSCC, February 2026) is the first shared cross-agency vocabulary for financial AI governance. Examiners from the OCC, FDIC, NCUA, and Federal Reserve are beginning to reference this lexicon in supervisory conversations. An institution that speaks this vocabulary fluently is demonstrating governance maturity — not just technical sophistication.

## AIEOG VOCABULARY — DEFINITIONS YOUR EXAMINERS WILL RECOGNIZE

|                              |                                                                                                                                                                                                                                                                                                        |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Artificial intelligence (AI) | <div>A machine-based system that can, for a given set of objectives, make predictions, recommendations, or decisions influencing real or virtual environments. AI systems are designed to operate with varying levels of autonomy.</div> <div>AIEOG AI Lexicon, February 2026</div>                    |
| AI governance                | <div>The framework of policies, procedures, and controls an institution uses to manage the development, deployment, monitoring, and decommissioning of AI systems — including oversight structures, accountability assignments, and audit trails.</div> <div>AIEOG AI Lexicon, February 2026</div>     |
| AI use case inventory        | <div>A living register of all AI systems an institution uses or intends to use, documenting the business purpose, data inputs, risk tier, validation status, and responsible owner for each use case.</div> <div>AIEOG AI Lexicon, February 2026</div>                                                 |
| Hallucination                | <div>Output generated by an AI model that is factually incorrect, nonsensical, or fabricated — but presented by the model with apparent confidence. A hallucination risk management plan is required for any high-stakes AI output used in decisions.</div> <div>AIEOG AI Lexicon, February 2026</div> |
| Human-in-the-loop (HITL)     | <div>A system design in which a human reviewer is required to evaluate and approve AI-generated outputs before those outputs are acted upon. For regulated decisions (credit, compliance), HITL is a baseline governance requirement.</div> <div>AIEOG AI Lexicon, February 2026</div>                 |
| Explainability               | <div>The degree to which the reasoning behind an AI system's output can be understood and communicated in plain language. Under ECOA / Reg B, adverse action notices require an explanation that cannot be satisfied by "the model said so."</div> <div>AIEOG AI Lexicon, February 2026</div>          |

# Examiner readiness — continued.

|                     |                                                                                                                                                                                                                                                                                                                                 |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Third-party AI risk | <div>The risk arising from an institution's use of AI systems developed, operated, or hosted by a third party. Requires application of Interagency TPRM Guidance including vendor due diligence, contractual protections, ongoing monitoring, and concentration risk analysis.</div> <div>AIEOG AI Lexicon, February 2026</div> |
| Model risk          | <div>The potential for adverse consequences from decisions based on incorrect or misused model outputs. For generative AI, model risk extends to hallucinated outputs, prompt injection, and unintended behavioral drift after foundational model updates.</div> <div>SR 11-7 / AIEOG AI Lexicon cross-reference</div>          |
| AI bias             | <div>Systematic and unfair discrimination in AI outputs resulting from biased training data, model architecture, or deployment context. Fair lending regulators are specifically focused on whether AI-assisted underwriting perpetuates disparate impact under ECOA / Reg B.</div> <div>AIEOG AI Lexicon, February 2026</div>  |
| Generative AI       | <div>AI systems capable of generating new content — text, images, code, audio — based on patterns learned from training data. Distinct from predictive AI in that outputs are novel rather than selected from a fixed category.</div> <div>AIEOG AI Lexicon, February 2026</div>                                                |

## REVIEW-READY DOCUMENT CHECKLIST

Have these available on the day of examination. For each item, maintain both a current version and a dated history showing the governance program has been operating, not just assembled in response to the examination notice.

- AI use case inventory — current, dated, owner-assigned
- AI governance policy — board-approved, with annual review cycle
- Vendor evaluation records for each AI tool (Chapter 4 scorecard or equivalent)
- SR 11-7 model risk mapping document (Chapter 3 framework or equivalent)
- Shadow AI discovery log — at minimum one cycle completed
- HITL documentation for any AI-assisted lending or compliance workflow
- Hallucination incident log (even if empty — the log itself demonstrates awareness)
- Board presentation on AI governance — within prior 12 months
- Staff training records — AI acceptable use training completion by role
- Adverse action notice review — confirm AI-generated reasoning is not cited verbatim

### Board reporting language

The AI Banking Institute recommends a quarterly AI governance summary to the full board, covering: (1) active AI tools by department and risk tier; (2) any vendor evaluation changes; (3) shadow AI discovered and remediated; (4) staff training completion rates; (5) any incidents involving AI-generated outputs. Five slides. Twenty minutes. Sufficient for most community bank and credit union governance requirements.

Sources: AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC (February 2026). GAO-25-107197, US Government Accountability Office (May 2025) — no comprehensive AI-specific banking framework yet; SR 11-7 and TPRM guidance apply. Cornerstone Advisors AI Playbook for Banks and Credit Unions (2025).  
This guide is provided for governance guidance purposes only and does not constitute legal advice. Consult your institution's counsel and

